Università di Genova
DIBRIS DIPARTIMENTO
DI INFORMATICA, BIOINGEGNERIA,
ROBOTICA E INGEGNERIA DEI SISTEMI

CastaWhale-VCC Final Project

Member: Marco Castagna S4700984

Project Overview (My Interpretation)

- **The Vision:** Starting from virtualized infrastructure (Vagrant) to build a resilient, *production-ready* Swarm stack.
- **What makes it "Production-Ready"?**
  - *Security & Least Privilege:* Vaulted secrets, no exposed backend ports, and read-only mounts.
  - *High Availability & Scalability:* Multi-replica Swarm services with node placement constraints.
  - *State & Caching:* Redis integration for distributed session management.
  - *Observability:* Fully automated monitoring (metrics + logs) via Grafana provisioning.
- **Core Stack:** Traefik, Authelia + Redis, Forgejo, PostgreSQL, Prometheus, Loki, Grafana.

What I Learned (Technical Concepts)

- **Infrastructure as Code:** Designing a microservices infrastructure from the ground up, leveraging Ansible for 100% automation with zero human intervention.
- **Distributed Systems:** Evolving from local Docker Compose to Docker Swarm, mastering concepts like overlay networks, internal DNS, and declarative desired state.
- **Modern Authentication:** Deploying advanced Identity and Access Management (OIDC via Authelia) across a distributed architecture.
- **Secrets Lifecycle:** Securing sensitive data from end to end using the powerful combination of Ansible Vault and Docker Secrets.
- **Observability:** Building automated monitoring pipelines for metric scraping (Prometheus) and log aggregation (Loki).

The Most Surprising Issue Encountered

- **Grafana OIDC & x509 Certificates**
  - *S*erver-to-server token exchange failed because Grafana rejected the HTTPS connection to Authelia (`x509: certificate signed by unknown authority`), not trusting the local custom CA.
  - *What I've done:* Built a custom Grafana container entrypoint to inject the CA certificates as `root`, followed by a secure privilege drop via `su-exec` to run Grafana safely as a non-privileged user.

Key Metric + Log Insight (Demo Preview)

- **Edge Traffic (Traefik):** Real-time tracking of HTTP status codes, error gauges ($4xx$/$5xx$), and method distributions.
- **Node Health (Node Exporter):** Multi-node monitoring of CPU, RAM usage, Disk I/O, and load averages.
- **Services Status:** Live indicators for container states (Up/Down) and backend request error rates.
- **Log Correlation (Loki):** Direct pairing of quantitative performance spikes with qualitative backend error streams.
- **Fault Injection (Live Demo):** Stress-testing via a custom `curl` script to dynamically trigger metrics and log streams.

Possible Improvements

- **High Availability Database:** Moving from a single PostgreSQL instance to a distributed, replicated database cluster to eliminate Single Points of Failure (SPOF).
- **Advanced Service Discovery:** Integrating a dedicated internal DNS server (such as CoreDNS) instead of relying solely on Docker's embedded DNS, enabling finer control over multi-network routing.
- **Runtime Security Auditing:** Deploying tools like Falco to monitor abnormal container behaviors and system call anomalies in real time.